

DOCUMENTACIÓN TÉCNICA

Enova Backend API

Referencia completa de endpoints REST para respondientes, clientes (empresas) y administradores.

BASE URL

`https://enova-backend.onrender.com`

PREFIJO DE API

`/api`

Generado el 2026-09-14 a partir del código fuente del repositorio Enova-backend.

Repositorio: Enova-backend • Runtime: Node.js / Express / PostgreSQL (Sequelize)

INTRODUCCIÓN

Cómo funciona esta API

Enova Backend es el servicio central de la plataforma Enova/OpinaCash: gestiona respondientes, empresas clientes (creadoras de encuestas), encuestas, respuestas, resultados/análítica, pagos (ledger interno + top-ups reales vía Conekta) y la Perfilación Quirúrgica (scoring socioeconómico Graffar).

Actores del sistema

- Usuario / Respondiente (User) — persona que responde encuestas, gana saldo en wallet y opcionalmente pasa por la Perfilación Quirúrgica. Login en `/api/auth`.
- Cliente (Client) — empresa que crea y publica encuestas, paga por publicarlas y consulta resultados. Login en `/api/clients`.
- Admin — usuario con role "admin" dentro de la tabla de usuarios; acceso total a resultados y gestión de usuarios.
- Client Admin — cliente con permisos elevados; puede ver encuestas y resultados de TODOS los clientes, no solo los propios.

Autenticación

La API usa JWT en cookies `httpOnly` (no `localStorage`) más un token CSRF de doble envío. En login/refresh se setean 3 cookies: access token (~1h), refresh token (~7 días, con path restringido a la ruta de refresh) y csrf token. Como el backend vive en un dominio distinto al frontend (`enova-backend.onrender.com` vs. `opinacash.com` / `*.vercel.app`), la cookie CSRF no es legible por JS del frontend — por eso el `csrfToken` también se devuelve en el body de `/login` y `/refresh-token`, y el frontend debe reenviarlo manualmente en el header `X-CSRF-Token` en cada request mutante.

```
Cookies (httpOnly, Secure, SameSite=None):
  accessToken  - válido 1 hora
  refreshToken - válido 7 días, solo enviado a /api/auth/refresh-token
                (o /api/clients/refresh-token para clientes)
  csrfToken    - espejo no-httpOnly del token CSRF

Headers requeridos en requests autenticados desde el navegador:
Cookie: (enviadas automáticamente con credentials: "include")
X-CSRF-Token: <csrfToken devuelto por /login o /refresh-token>
```

CORS

credentials: true, con origin dinámico. Permitidos explícitamente: `opinacash.com`, `www.opinacash.com`, `localhost:5174`, subdominios `*.vercel.app` (previews) y cualquier origen que contenga `render.com` u `onrender.com`. Peticiones sin header Origin (Postman, apps nativas, servidor-a-servidor) siempre se permiten.

Convención de errores

Los controladores devuelven JSON consistente. Éxito: 200/201 con el recurso o `{ message }`. Error de validación: 400 con `{ message }` o `{ errors: [...] }` (express-validator). No autenticado: 401. Prohibido: 403. No encontrado: 404. Error interno: 500 con `{ message: "Internal server error", error }`. Algunos endpoints (perfilación, pagos) usan además un campo `{ success: boolean }`.

Health check

GET `/health`

AUTH: PÚBLICO

Fuera del prefijo `/api`. Confirma que el servidor y la base de datos están arriba.

RESPONSE

```
{
  "status": "OK",
  "message": "Server is running",
  "timestamp": "2026-09-14T20:59:03.704Z",
  "allowedOrigins": ["https://www.opinacash.com", "..."]
}
```

Autenticación de Respondientes

Prefijo: `/api/auth` — registro, login, sesión y verificación de WhatsApp (Filtro Preliminar) para usuarios que responden encuestas.

POST `/api/auth/register`

AUTH: PÚBLICO

Registra un nuevo respondiente. Envía email de confirmación; el login se bloquea hasta confirmar la cuenta.

REQUEST BODY

```
{
  "email": "string (requerido)",
  "password": "string (requerido)",
  "firstName": "string (requerido)",
  "lastName": "string (requerido)",
  "role": "string (opcional, default 'user')",
  "gender": "string",
  "age": "number",
  "phone_number": "string",
  "city": "string",
  "country": "string",
  "postalCode": "string",
  "birthYear": "number",
  "educationLevel": "string",
  "educationCode": "string",
  "occupation": "string",
  "hasChildren": "boolean",
  "childrenCount": "number",
  "childrenAges": "array",
  "residentialArea": "string",
  "purchaseResponsibility": "string",
  "consentAccepted": "boolean (requerido = true)",
  "consentVersion": "string"
}
```

RESPONSE

```
201 Created
{
  "message": "User registered successfully! Please check your email to confirm your account.",
  "user": { "id": 1, "email": "...", "role": "user" }
}
```

Errores: 409 email ya registrado · 400 faltan campos requeridos o falta consentimiento · 500 error de plantilla de email / error interno.

POST `/api/auth/login`

AUTH: PÚBLICO

Autentica un respondiente. Setea cookies de sesión y devuelve el csrfToken en el body.

REQUEST BODY

```
{ "email": "string", "password": "string" }
```

RESPONSE

```
200 OK
{ "message": "Login successful!", "csrfToken": "..." }
```

Errores: 401 credenciales incorrectas · 403 email no confirmado.

POST /api/auth/refresh-token

AUTH: PÚBLICO (REQUIERE COOKIE/REFRESHTOKEN)

Renueva el access token usando la cookie de refresh (o un refreshToken en el body para llamadas no-navegador). Rota también el csrfToken.

REQUEST BODY

```
{ "refreshToken": "string (opcional si viene por cookie)" }
```

RESPONSE

```
200 OK
{ "message": "Token refreshed successfully!", "csrfToken": "..." }
```

POST /api/auth/logout

AUTH: PÚBLICO

Limpia las cookies de autenticación en el navegador (los JWT no se revocan server-side).

RESPONSE

```
200 OK
{ "message": "Logged out." }
```

POST /api/auth/forgot-password

AUTH: PÚBLICO

Solicita el envío de un email con enlace para restablecer la contraseña.

POST /api/auth/reset-password

AUTH: PÚBLICO

Restablece la contraseña usando el token recibido por email.

POST /api/auth/whatsapp/send-otp

AUTH: RESPONDIENTE

Envía un código OTP por WhatsApp para verificar el número de teléfono (parte del Filtro Preliminar).

POST /api/auth/whatsapp/verify-otp

AUTH: RESPONDIENTE

Verifica el OTP enviado por WhatsApp y marca el número como verificado.

GET /api/auth/profile

AUTH: RESPONDIENTE

Endpoint de ejemplo: devuelve el payload del JWT decodificado (req.user).

RESPONSE

```
{ "message": "This is your profile", "user": { "userId": 1, "role": "user", ... } }
```

POST /api/auth/admin-action

AUTH: ADMIN

Endpoint de ejemplo para acciones exclusivas de administrador.

Usuarios (Respondientes)

Prefijo: `/api/users` — perfil, wallet, puntaje de lealtad y administración de cuentas de respondientes.

GET `/api/users/me`

AUTH: RESPONDIENTE

Perfil del usuario autenticado. Elimina campos sensibles (password, tokens) antes de responder.

RESPONSE

```
{
  "id": 1, "email": "...", "firstName": "...", "lastName": "...",
  "role": "user", "walletBalance": 0, "score": 0,
  "hasphone_number": true, "...": "..."
}
```

PATCH `/api/users/me`

AUTH: RESPONDIENTE

Actualiza el perfil propio del usuario autenticado.

GET `/api/users`

AUTH: ADMIN

Lista todos los usuarios. Soporta filtros opcionales por query string.

GET `/api/users/:id`

AUTH: ADMIN

Obtiene un usuario por ID.

URL PARAMS `id` — integer

PATCH `/api/users/:id`

AUTH: RESPONDIENTE (PROPIO) O ADMIN

Actualiza el perfil de otro usuario. Un usuario normal solo puede editar su propio ID.

URL PARAMS `id` — integer

DELETE `/api/users/:id`

AUTH: ADMIN

Baja lógica (soft-delete) de un usuario.

URL PARAMS `id` — integer

GET `/api/users/confirm/:token`

AUTH: PÚBLICO

Confirma el email de un usuario a partir del token enviado por correo.

URL PARAMS `token` — string

GET `/api/users/:id/wallet`

AUTH: PÚBLICO

Devuelve el saldo de wallet de un usuario.

URL PARAMS `id` — integer

PATCH /api/users/:id/score

AUTH: ADMIN

Actualiza el puntaje de lealtad (score) de un usuario.

URL PARAMS id – integer

Clientes (Empresas)

Prefijo: /api/clients — cuentas de las empresas que crean y publican encuestas. Tienen su propio sistema de autenticación, independiente del de respondientes.

POST /api/clients/register

AUTH: PÚBLICO

Registra una nueva empresa cliente. Envía email de confirmación.

REQUEST BODY

```
{
  "companyName": "string",
  "contactEmail": "string",
  "password": "string",
  "industry": "string",
  "contactName": "string",
  "phone": "string"
}
```

RESPONSE

```
201 Created
{ "message": "Registration successful! Please check your email." }
```

GET /api/clients/confirm/:token

AUTH: PÚBLICO

Confirma el email de la cuenta cliente.

URL PARAMS token – string

POST /api/clients/login

AUTH: PÚBLICO

Autentica un cliente. Setea cookies de sesión y devuelve datos del cliente + csrfToken en el body.

REQUEST BODY

```
{ "contactEmail": "string", "password": "string" }
```

RESPONSE

```
200 OK
{ "id": 1, "companyName": "...", "contactEmail": "...", "creditBalance": 0, "csrfToken":
  "..."}
}
```

POST /api/clients/logout

AUTH: PÚBLICO

Limpia las cookies de sesión del cliente.

POST /api/clients/forgot-password

AUTH: PÚBLICO

Solicita email de restablecimiento de contraseña para la cuenta cliente.

POST /api/clients/reset-password/:token

AUTH: PÚBLICO

Restablece la contraseña de la cuenta cliente.

URL PARAMS token – string

GET /api/clients/validate-reset-token/:token

AUTH: PÚBLICO

Valida si un token de reseteo sigue siendo válido, antes de mostrar el formulario.

URL PARAMS token – string

POST /api/clients/refresh-token

AUTH: PÚBLICO (REQUIERE COOKIE DE REFRESH)

Renueva el access token del cliente.

GET /api/clients/me

AUTH: CLIENTE

Perfil de la empresa cliente autenticada.

GET /api/clients/admin/all-clients

AUTH: CLIENT ADMIN

Lista todas las empresas clientes registradas en el sistema.

GET /api/clients/admin/dashboard

AUTH: CLIENT ADMIN

Estadísticas globales del sistema para el dashboard de administración de clientes.

Encuestas

Prefijo: `/api/surveys` — creación, listado y respuesta de encuestas. Las respuestas del respondiente se envían mediante un `accessToken` único por encuesta, no por ID numérico.

POST `/api/surveys`

AUTH: CLIENTE O ADMIN

Crea una nueva encuesta. Si el request viene de un cliente autenticado, `clientId` se asigna automáticamente; un admin puede especificar `clientId` manualmente. Genera un `accessToken` único usado por los respondientes para acceder a la encuesta.

REQUEST BODY

```
{
  "title": "string (requerido)",
  "description": "string",
  "questions": [                                // array (requerido)
    {
      "questionId": "string",
      "question": "string",
      "type": "text | multiple | scale | ...",
      "required": true,
      "options": ["Opción A", "Opción B"],      // si type === 'multiple'
      "multipleSelections": "yes | no",         // si multipleSelections === 'yes'
      "selectionLimit": 2,                      // si multipleSelections === 'yes'
      "otherOption": false                     // habilita opción "Otro"
    }
  ],
  "expirationTime": "ISO date",
  "responseLimit": 100,                        // # de respondientes, no de filas
  "surveyType": "standard | surgical_profiling",
  "clientId": 1                               // solo si lo crea un admin
}
```

RESPONSE

```
201 Created
{
  "id": 10, "title": "...", "description": "...", "questions": [...],
  "accessToken": "9f1c...", "expirationTime": "...", "status": "active",
  "responseLimit": 100, "clientId": 1, "createdAt": "...", "updatedAt": "..."
}
```

Al crearse, se descuenta (best-effort, no bloqueante) el saldo del cliente por publicar la encuesta — ver módulo Pagos.

DELETE `/api/surveys/:id`

AUTH: CLIENTE O ADMIN

Elimina una encuesta.

URL PARAMS `id` — integer

GET `/api/surveys/client-surveys`

AUTH: CLIENTE O ADMIN

Lista las encuestas del cliente autenticado (o todas si es admin).

GET `/api/surveys/my-surveys`

AUTH: CLIENTE

Lista las encuestas creadas por el cliente autenticado.

GET /api/surveys/debug/my-surveys

AUTH: CLIENTE

Variante de depuración de /my-surveys, con información adicional para troubleshooting.

GET /api/surveys/active

AUTH: ADMIN

Lista todas las encuestas activas del sistema.

GET /api/surveys/respond

AUTH: RESPONDIENTE

Obtiene el contenido de una encuesta a partir de su accessToken, para presentarla al respondiente.

QUERY PARAMS ?accessToken=<token de la encuesta>

RESPONSE

```
{ "id": 10, "title": "...", "questions": [...], "status": "active", ... }
```

POST /api/surveys/respond

AUTH: RESPONDIENTE

Envía las respuestas de un respondiente a una encuesta (validación ESTRICTA: cada respuesta debe cumplir exactamente el esquema de su pregunta). Si la encuesta es de tipo surgical_profiling, dispara automáticamente el cálculo Graffar. Además acredita el pago al wallet del respondiente.

QUERY PARAMS ?accessToken=<token de la encuesta>

REQUEST BODY

```
[
  { "questionId": "q1", "answer": "Opción A" },
  { "questionId": "q2", "answer": ["Opción A", "Opción C"] },
  { "questionId": "q3", "answer": { "selectedOption": "other", "otherText": "..." } }
]
```

RESPONSE

```
200 OK
{
  "message": "Responses saved successfully",
  "surveyTitle": "...", "surveyId": 10, "userId": 1,
  "questionsAnswered": 3, "responseTime": "42ms"
}
```

Errores: 400 pregunta no encontrada / respuesta inválida / límite de respuestas alcanzado · 401 no autenticado · 404 encuesta no encontrada.

POST /api/surveys/respond-permissive

AUTH: RESPONDIENTE

Variante TOLERANTE de envío de respuestas: acepta formas de respuesta menos estrictas que /respond (útil para clientes frontend más antiguos o datos parcialmente inconsistentes).

QUERY PARAMS ?accessToken=<token de la encuesta>

REQUEST BODY

```
[ { "questionId": "q1", "answer": "..." } ]
```

Resultados y Analítica

Prefijo: `/api/results` — consulta de respuestas guardadas, analítica agregada, exportación y asignación de puntos. Existen tres familias de rutas con el mismo shape de datos pero distinto scope de autorización: sin prefijo (admin global), `/client/*` (solo encuestas propias del cliente) y `/client-admin/*` (cualquier encuesta, para client admins).

POST `/api/results/submit`

AUTH: RESPONDIENTE

Guarda UNA respuesta individual (pregunta por pregunta) — ruta de bajo nivel, distinta del flujo completo `POST /api/surveys/respond` que guarda todas las respuestas de la encuesta a la vez.

REQUEST BODY

```
{ "surveyId": 10, "userId": 1, "questionId": "q1", "answer": "..."} 
```

RESPONSE

```
201 Created
{ "message": "Response saved successfully!", "result": { ... } }
```

Rutas de administración global (Admin)

GET `/api/results/survey/:surveyId`

AUTH: ADMIN

Todas las respuestas de una encuesta.

URL PARAMS `surveyId` – integer

GET `/api/results/user/:userId`

AUTH: ADMIN

Todas las respuestas dadas por un usuario.

URL PARAMS `userId` – integer

GET `/api/results/survey/:surveyId/question/:question`

AUTH: ADMIN

Respuestas de una encuesta filtradas por una pregunta específica.

URL PARAMS `surveyId` – integer · `question` – string

GET `/api/results/export/:surveyId`

AUTH: ADMIN

Exporta las respuestas de una encuesta a un archivo Excel.

URL PARAMS `surveyId` – integer

GET `/api/results/survey/:surveyId/with-users`

AUTH: ADMIN

Respuestas de una encuesta enriquecidas con los datos demográficos del respondiente.

URL PARAMS `surveyId` – integer

Rutas para clientes (solo sus propias encuestas)

GET /api/results/client/survey/:surveyId

AUTH: CLIENTE

Respuestas de una encuesta propia.

URL PARAMS surveyId – integer

GET /api/results/client/survey/:surveyId/question/:question

AUTH: CLIENTE

Respuestas de una pregunta específica, encuesta propia.

URL PARAMS surveyId – integer · question – string

GET /api/results/client/survey/:surveyId/with-users

AUTH: CLIENTE

Respuestas con datos demográficos del respondiente, encuesta propia.

URL PARAMS surveyId – integer

GET /api/results/client/survey/:surveyId/analytics

AUTH: CLIENTE

Analítica agregada (demografía, distribución de respuestas) de una encuesta propia.

URL PARAMS surveyId – integer

GET /api/results/client/survey/:surveyId/export

AUTH: CLIENTE

Exporta las respuestas de una encuesta propia. Formato por defecto Excel; una fila por respondiente con columnas demográficas.

QUERY PARAMS ?format=xlsx (default) | csv | pdf – pdf genera un reporte legible por pregunta, no una tabla cruda

URL PARAMS surveyId – integer

GET /api/results/client/survey/:surveyId/results-with-scores

AUTH: CLIENT ADMIN

Resultados de una encuesta propia junto con los puntos/score otorgados a cada usuario.

URL PARAMS surveyId – integer

POST /api/results/client/survey/:surveyId/user/:userId/award-points

AUTH: CLIENT ADMIN

Otorga puntos de lealtad a un usuario por su participación en una encuesta propia.

URL PARAMS surveyId – integer · userId – integer

Rutas de Client Admin (cualquier cliente)

GET /api/results/client-admin/all-surveys

AUTH: CLIENT ADMIN

Lista TODAS las encuestas de TODOS los clientes del sistema.

GET /api/results/client-admin/survey/:surveyId/responses

AUTH: CLIENT ADMIN

Respuestas de cualquier encuesta, sin restricción de propiedad.

URL PARAMS surveyId – integer

GET /api/results/client-admin/survey/:surveyId/question/:question

AUTH: CLIENT ADMIN

Respuestas por pregunta de cualquier encuesta.

URL PARAMS surveyId – integer · question – string

GET /api/results/client-admin/survey/:surveyId/with-users

AUTH: CLIENT ADMIN

Respuestas con datos de usuario de cualquier encuesta.

URL PARAMS surveyId – integer

GET /api/results/client-admin/survey/:surveyId/analytics

AUTH: CLIENT ADMIN

Analítica agregada de cualquier encuesta.

URL PARAMS surveyId – integer

GET /api/results/client-admin/survey/:surveyId/results-with-scores

AUTH: CLIENT ADMIN

Resultados con score de cualquier encuesta.

URL PARAMS surveyId – integer

POST /api/results/client-admin/survey/:surveyId/user/:userId/award-points

AUTH: CLIENT ADMIN

Otorga puntos en cualquier encuesta del sistema.

URL PARAMS surveyId – integer · userId – integer

GET /api/results/client-admin/dashboard

AUTH: CLIENT ADMIN

Estadísticas globales de encuestas/respuestas para el dashboard de administración.

Pagos

Prefijo: `/api/payments` — ledger interno de movimientos (wallet del respondiente / crédito del cliente) y recarga de saldo real de clientes vía Conekta (checkout hospedado).

GET `/api/payments/me`

AUTH: RESPONDIENTE

Historial de ganancias del respondiente autenticado + saldo actual de wallet.

RESPONSE

```
{
  "success": true,
  "walletBalance": 45.5,
  "transactions": [ { "amount": 5, "type": "survey_reward", "createdAt": "..."} ]
}
```

GET `/api/payments/client/me`

AUTH: CLIENTE

Historial de cargos del cliente autenticado + saldo de crédito actual.

RESPONSE

```
{ "success": true, "creditBalance": 900, "transactions": [ ... ] }
```

POST `/api/payments/client/topup`

AUTH: CLIENTE

Crea una sesión de checkout hospedado por Conekta para que el cliente recargue saldo real. Devuelve la URL de checkout a la que redirigir al usuario.

POST `/api/payments/conekta/webhook/:secret`

AUTH: WEBHOOK

Recibido por los servidores de Conekta (no por un navegador) al confirmarse un pago; acredita el top-up en el crédito del cliente. Autenticado por un secreto en la URL, no por cookies/CSRF.

URL PARAMS `secret` – string (compartido con Conekta)

Perfilación Quirúrgica (Graffar)

Prefijo: `/api/profiling` — scoring socioeconómico basado en la fórmula Graffar. En producción se dispara automáticamente cuando un respondiente completa una encuesta marcada `surveyType: "surgical_profiling"` (vía POST `/api/surveys/respond`); estas rutas exponen el resultado y ofrecen un atajo manual para pruebas.

POST `/api/profiling/surgical`

AUTH: RESPONDIENTE

Atajo manual/QA: corre un set de respuestas ya armado directamente por la fórmula Graffar, sin pasar por una encuesta real. Los respondientes reales nunca llaman esta ruta directamente.

REQUEST BODY

```
{ /* respuestas Graffar, ver config/graffarQuestionMap.js */ }
```

RESPONSE

```
201 Created
{ "success": true, "profile": { "estrato": "...", "graffar": 0, "...": "..." } }
```

GET `/api/profiling/surgical/me`

AUTH: RESPONDIENTE

Devuelve el resultado más reciente de la Perfilación Quirúrgica del respondiente autenticado.

RESPONSE

```
200 OK (o 404 si aún no respondió)
{ "success": true, "profile": { "estrato": "...", "graffar": 0, "...": "..." } }
```

GET `/api/profiling/summary`

AUTH: RESPONDIENTE

Vista consolidada de todo lo que se sabe del respondiente: datos del Filtro Preliminar (registro), resultado de la Perfilación Quirúrgica y sus ganancias — equivalente a combinar `/users/me` + `/profiling/surgical/me` + `/payments/me` en una sola llamada.

RESPONSE

```
{
  "success": true,
  "filtroPreliminar": { "nombre": "...", "email": "...", "whatsapp": "...",
    "whatsappVerificado": true, "pais": "...", "...": "..." },
  "perfilacionQuirurgica": { "estrato": "...", "graffar": 0, "bandaObjetiva": "...",
    "...": "..." },
  "pagos": { "walletBalance": 45.5, "totalGanado": 45.5, "movimientos": 3 }
}
```

Media (Imágenes / Video de Preguntas)

Prefijo: /api/media — subida de archivos multimedia para preguntas de encuestas. Los archivos servidos quedan públicos bajo /uploads.

POST /api/media/upload

AUTH: CLIENTE

Sube un archivo de imagen o video para adjuntar a una pregunta de encuesta. multipart/form-data, campo "file". Límite 25MB; las imágenes se procesan con sharp en memoria (no se guarda el original en disco).

REQUEST BODY

```
Content-Type: multipart/form-data
file: <binary>
```

RESPONSE

```
{ "url": "https://enova-backend.onrender.com/uploads/<archivo>", "...": "..." }
```

Los archivos servidos en /uploads llevan Cross-Origin-Resource-Policy: cross-origin para permitir /<video> desde otros orígenes (Pulse / OpinaCash).
